

Data Requirement Analysis

GRC Risk and Compliance Tracking System

Entity requirements

The system will store and manage information about departments, employees, risks, controls, compliance requirements, and audits in order to support basic Governance, Risk, and Compliance tracking within an organization.

For each department, the Department entity contains a unique department_id and a department_name. A department may have zero or many employees.

For each employee, the Employee entity contains a unique employee_id, employee_name, and job_title. Each employee must belong to exactly one department. An employee may own zero, one, or many risks, and an employee may own zero, one, or many controls.

For each risk, the Risk entity contains a unique risk_id, risk_title, risk_level, and risk_status and must have exactly one employee as its owner. The department associated with the risk is determined through that employee's department. A risk may be mitigated by zero, one, or many controls.

For each control, the Control entity contains a unique control_id, control_name, and control_status. Each control must have exactly one employee as its owner. A control may mitigate zero, one, or many risks, may satisfy zero, one, or many compliance requirements, and may be evaluated in zero, one, or many audits.

For each compliance requirement, the Compliance Requirement entity contains a unique requirement_id, framework_name, and requirement_code. A compliance requirement may be satisfied by zero, one, or many controls.

For each audit, the Audit entity contains a unique audit_id, audit_name, and audit_date. An audit may evaluate zero, one, or many controls. For each audit-control evaluation, the system stores a finding_status that represents the result of evaluating a specific control during a specific audit.

Relationship Requirements

The relationship between Department and Employee indicates that one department may have zero, one, or many employees, while each employee must belong to exactly one department.

The relationship between Employee and Risk indicates that one employee may own zero, one, or many risks, while each risk must have exactly one employee as its owner.

The relationship between Employee and Control indicates that one employee may own zero, one, or many controls, while each control must have exactly one employee as its owner.

The relationship between Risk and Control indicates that one risk may be mitigated by zero, one, or many controls, and one control may mitigate zero, one, or many risks.

The relationship between Control and Compliance Requirement indicates that one control may satisfy zero, one, or many compliance requirements, and one compliance requirement may be satisfied by zero, one, or many controls.

The relationship between Audit and Control indicates that one audit may evaluate zero, one, or many controls, and one control may be evaluated in zero, one, or many audits. The relationship between Audit and Control includes the attribute `finding_status`, which records the result of the evaluation.